

Three machines. One externally enforced release.

The NVFlare provisioning node creates the protected workload. An independent trust domain owns key release. The adversarial CoCo operator owns the cluster—but never the plaintext or release authority.

WORKLOAD AUTHORITY

NVFlare provisioning node

- Builds and tests the plaintext image
- Signs the immutable OCI digest
- Encrypts layers with a fresh release key
- Pushes only ciphertext to the registry
- Generates strict Agent policy + measured InitData
- Defines release authorization and Pod YAML

Docker cosign skopeo genpolicy openssl

TRUST + RELEASE AUTHORITY

Secure services

- **TLS private registry** stores encrypted OCI images
- **Trustee** fronts KBS, AS and RVPS
- Verifies platform/workload handoffs
- Owns SNP measurement and TCB references
- Stores image keys and exact-path rules
- Installs owner-defined release intent only after validation

KBS AS RVPS EAR LocalFS

ADVERSARIAL OPERATOR

CoCo cluster

- Kubernetes + containerd + Calico
- Digest-pinned Kata Containers runtime
- NVIDIA GPU Operator + confidential GPU
- AMD SEV-SNP Kata guest
- Receives public chart/pins, CAs and Pod YAML
- Controls availability—not key release

Kubernetes Kata SEV-SNP H200

PROVISIONING → SECURE SERVICES

Encrypted image; secret image key; signature public key; image policy; exact release-policy fragment.

COCO GUEST ↔ SECURE SERVICES

Fresh CPU/GPU evidence in; JWE-encrypted approved resources out—only after every binding agrees.

PROVISIONING → COCO IT

One digest-pinned Pod YAML plus an independently authenticated SHA-256; no workload or trust-administration secret.

Trusted reference meets live evidence at one equality gate.

The authoritative SNP measurement comes from a challenge-bound AMD-signed report. The secure-services trust domain authenticates that reference, then compares every live guest against it before KBS considers workload-specific release policy.

1 · Establish the trusted reference

- 1 Fresh challenge**
Trusted reference host creates a random 64-byte nonce.
- 2 Collector Pod**
Kata CoCo guest runs `snpguest`; nonce becomes signed SNP `REPORT_DATA`.
- 3 Cryptographic verification**
Verify AMD ARK/ASK/VCEK chain, report signature, TCB, checksums and exact nonce bytes.
- 4 Extract signed measurement**
Stage 09 reads report bytes `0x90..0xbf`: `c85a...afd0`.
- 5 Authenticated handoff**
Stage 10 exports five-value JSON via the provisioning node; a separate launch contract goes to the image owner.
- 6 Install in secure services**
The trust administrator authenticates the sender and approves RVPS values; AS uses its own policies. No signed bundle.

Diagnostic only: offline `sev-snp-measure` output is retained for investigation; it cannot replace the hardware-signed report measurement.

2 · Appraise every live launch

- 1 Measured Kata boot**
CoCo launches the digest-pinned RuntimeClass and measured InitData.
- 2 Fresh evidence**
Guest sends AMD SNP evidence, InitData/HOST_DATA and NVIDIA GPU evidence to Trustee.
- 3 KBS attests both CPU + GPU and**
AS/RVPS appraises AMD SEV-SNP measurement, TCB and debug/migration state
NVIDIA GPU evidence, returning one signed EAR.

APPROVED REFERENCES

CPU: SNP measurement + TCB
GPU: NVIDIA appraisal policy

=

LIVE EVIDENCE

CPU: AMD-signed SNP report
GPU: NVIDIA-signed claims

- 4 Both attestation results are mandatory**
KBS requires exactly `cpu0` + `gpu0` and each complete approved eight-component trust vector. Either failure denies every resource.
- 5 KBS resource decision**
Match InitData hash, image digest, command and the actual requested resource path.
- 6 Release inside the TEE**
JWE-encrypt image key and policies to the attested guest key; decrypt image only in guest memory.

What the CoCo owner can attack—and why it fails.

Each useful modification breaks at least one independent binding. The design protects confidentiality and launch integrity; it intentionally does not guarantee availability.

CoCo-owner attack	Independent mitigation and enforcement point	Outcome
Read registry/cache/host files	Image layers are encrypted before publication; KBS releases the key only to an attested guest public key.	Ciphertext only
Replace image, tag, manifest, or layer	Immutable digest, Cosign verification, authenticated encryption, Agent policy and KBS image binding must all agree.	No start / no key
Change command, UID, env, mounts, or OCI settings	Kata Agent policy constrains the exact container request; KBS independently binds command and image identity.	Request denied
Alter InitData, policy, endpoint, or CA	Exact InitData hash is carried in SNP HOST_DATA and authorized by the workload-specific KBS rule.	Release denied
Replace Kata kernel, firmware, rootfs, or runtime	Live AMD-signed SNP MEASUREMENT differs from the independently authenticated AS/RVPS reference.	CPU trust fails
Fake/replay evidence; enable debug/migration; downgrade TCB	Fresh session binding, AMD/EAR signatures, debug and migration checks, and four minimum reported-TCB floors.	Appraisal fails
Request another KBS path or release key	Actual path is evaluated on every request against an exact allow-list; resource policy is default deny.	Resource denied
Use exec, attach, copy, debug container, or SSH	Agent policy denies stream/exec operations; Pod has no SSH daemon, credentials, host mounts, or service-account token.	No guest shell
Inspect or modify guest memory	AMD SEV-SNP encrypts guest memory and protects guest integrity from the host and hypervisor.	Plaintext stays in TEE
Kill, pause, starve, or disconnect the Pod	Outside the confidentiality/integrity guarantee; an owner-controlled channel can detect failure.	DoS remains possible